ML-Based Cyber Threat Prediction

Literature Review

Domain: Cybersecurity and Machine Learning

By

NAGA GIREESH REDDY (24STUCHH010432)

MANGALI VISHNU DATTA (24STUCHH010201)

DWARAMPUDI NIHAR REDDY (24STUCHH010217)

THALUPURI MANIDEEP SATHYA (24STUCHH010104)

Under the Guidance of

Mr. M. Rama Krishnam Raju

In partial fulfilment for the award of the degree

Of

BACHELOR OF ENGINEERING

In

SPECIAL PROJECT

FACULTY OF SCIENCE & TECHNOLOGY

The ICFAI Foundation for Higher Education, Hyderabad

IcfaiTech

Faculty of Science & Technology (FST)

Literature Review

1. Introduction

This project, ML-Based Cyber Threat Prediction, applies Machine Learning to network intrusion and threat detection. Modern networks face a constantly growing volume and sophistication of cyberattacks, and traditional signature-based security tools are increasingly unable to keep pace with attacks that are unknown in advance, hidden inside encrypted channels, too numerous for analysts to triage, or deliberately engineered to fool the detection model itself. This literature review examines four specific, current problems within this space, each of which remains inadequately solved by existing systems even in recent (2024-2026) research.

1.1 Failure to Detect Zero-Day / Unknown Attacks

A zero-day attack uses a technique that has never been seen before, so it cannot be represented in any training dataset collected prior to the attack. ML classifiers trained only on known attack classes have no statistical basis to recognize such an attack when it occurs. This is compounded by attackers who deliberately engineer malware to look different on every infection (through obfuscation techniques such as polymorphism and metamorphism), specifically to defeat any detection method built around matching a fixed, previously seen pattern.

1.2 Blind Spot in Encrypted (TLS/QUIC) Traffic

With over 95% of internet traffic now encrypted, detection tools that depend on reading packet payloads (Deep Packet Inspection, signature matching) are structurally unable to inspect the vast majority of traffic they are meant to monitor. Newer protocols make this worse rather than better: QUIC (HTTP/3) and Encrypted Client Hello progressively hide even the transport-level metadata and destination information that defenders previously relied on when payload content was already unavailable.

1.3 Alert Fatigue from High False-Positive Rates

Security teams now receive thousands of alerts daily, and even highly accurate detection models still generate an unmanageable volume of false positives at enterprise scale, leading analysts to ignore or dismiss alerts — including real attacks. This is not solved simply by improving model accuracy: a system that is statistically correct but operationally unusable provides little real security value.

1.4 Adversarial Evasion Attacks Against ML-Based IDS

Attackers can deliberately craft small, mathematically calculated perturbations to network traffic that cause an otherwise accurate ML classifier to misclassify malicious traffic as benign, exposing a vulnerability that exists in the model itself rather than in the underlying attack. Unlike the first three problems, which concern what the model cannot see or cannot process fast enough, this problem concerns an adversary actively and deliberately attacking the detection system itself.

Sources reviewed for this study were selected using three criteria: relevance (each source had to directly address ML/AI-based network intrusion or threat detection rather than general cybersecurity topics), recency (publications were restricted to 2024-2026 wherever possible, since detection techniques and attacker behavior in this field change quickly enough that older sources risk being outdated), and domain credibility (peer-reviewed journals and conference papers, official standards bodies such as NIST and IETF, and primary industry threat-intelligence reports such as Microsoft/Omdia and WatchGuard, rather than unverified secondary sources or opinion pieces).

2. Previous Works and Studies

2.1 Problem 1 — Failure to Detect Zero-Day / Unknown Attacks

Title of Article: An intrusion detection model to detect zero-day attacks in unseen data using machine learning
Authors: Dai, Z., Por, L. Y., Chen, Y.-L., Yang, J., Ku, C. S., Alizadehsani, R., & Pławiak, P.
Article Source: PLOS ONE
Year of Publication: 2024

Zero-day exploitation has grown sharply as a share of advanced persistent threat (APT) activity, rising from roughly 18% of tracked APT campaigns in 2020 to approximately 34% by 2023. Two well-documented incidents illustrate the scale of impact: the SolarWinds supply-chain compromise, which used a previously unknown vulnerability to silently infiltrate critical infrastructure, and the Microsoft Exchange ProxyLogon exploit, which impacted more than 250,000 servers globally. Attackers also actively engineer malware to resist detection through obfuscation techniques such as polymorphism (changing code structure on each infection while preserving malicious function), metamorphism (rewriting code dynamically during execution), process hollowing (injecting code into a legitimate running process), and fileless execution (operating entirely in volatile memory, never writing a file to disk).

Existing detection approaches fall into four categories, each working differently. Signature-based detection compares files or traffic against a database of known attack patterns — fast, but blind to anything not already catalogued. Sandboxing executes suspicious samples in an isolated environment to observe their behavior before granting real access, but sophisticated malware can remain dormant during this observation window and only activate once released. Supervised ML classifiers (Random Forest, SVM, Decision Trees) learn statistical boundaries between benign and malicious traffic from labeled datasets such as NSL-KDD or CICIDS2017. Unsupervised anomaly detectors, such as Autoencoders, instead learn what normal traffic looks like and flag any traffic that deviates significantly (a high 'reconstruction error') as suspicious, without needing a labeled example of the attack itself.

Dai et al. (2024, PLOS ONE) directly tested a hybrid of the last two approaches — an Autoencoder combined with XGBoost or Random Forest — and found it reached 99.97-99.98% accuracy on attack data the model had never seen during training, substantially outperforming either method alone. In a further zero-shot test, a Random Forest trained on examples of only one malware subtype successfully generalized to correctly detect 14 entirely different, previously unencountered subtypes — direct evidence that this style of architecture does not require exhaustive labeled coverage of every possible attack to be effective against new ones.

2.2 Problem 2 — Blind Spot in Encrypted (TLS/QUIC) Traffic

Title of Article: Enhancing Network Intrusion Detection for TLS Traffic Using Deep Learning
Authors: Muttaqien, H., Niswar, M., Syarif, S., & Zainuddin, Z.
Article Source: Engineering, Technology & Applied Science Research (ETASR)
Year of Publication: 2025

Encryption is now the default state of internet traffic: over 95% of web traffic runs over HTTPS, and WatchGuard's 2025 threat report found that 96% of blocked malware was delivered over TLS. The problem is worsened by newer privacy-focused protocols — TLS 1.3 encrypts the server's certificate, QUIC (HTTP/3) encrypts transport metadata that TCP used to leave exposed, and Encrypted Client Hello (standardized as RFC 9849 in March 2026) now hides even the destination server name, one of the last reliable cleartext signals defenders had.

Existing systems take two different paths around this blind spot. In-line selective decryption (TLS Inspection) acts as a proxy that decrypts, inspects, and re-encrypts traffic — NIST SP 1800-37 (2025) formalizes this into a 'middle path' of decrypting only a narrow, high-risk slice of traffic rather than everything. Encrypted Traffic Analysis (ETA) instead infers intent without decrypting anything: handshake fingerprinting (JA3, and its more evasion-resistant successor JA4) hashes the cleartext handshake fields into a signature that can identify known malicious client software, while flow-based modelling analyses the physical 'shape' of a connection — packet-size sequences and timing (SPLT) — which survives every layer of encryption, including ECH.

Muttaqien et al. (2025, ETASR) combined these ideas into a CNN-BiLSTM deep learning model trained purely on this kind of metadata and reported 98.7% detection accuracy with only a 1.4% false-positive rate at 12.9 milliseconds per session — fast enough for real-time use without ever reading a packet's actual contents. The CNN branch of their architecture extracts spatial patterns such as packet-size distributions and JA3 fingerprint vectors, while the BiLSTM branch models temporal patterns such as handshake timing and connection beaconing rhythms, with the two branches fused into a single classification decision.

2.3 Problem 3 — Alert Fatigue from High False-Positive Rates

Title of Article: Alert Prioritisation in Security Operations Centres: A Systematic Survey on Criteria and Methods
Authors: Jalalvand, F., Chhetri, M. B., Nepal, S., & Paris, C.
Article Source: ACM Computing Surveys
Year of Publication: 2024

As organizations expand across cloud, IoT, and hybrid environments, many SOCs now receive over 10,000 alerts daily. The Microsoft/Omdia State of the SOC 2026 report found that 46% of all generated alerts are false positives and 42% go completely uninvestigated due to bandwidth constraints, while analysts are forced to pivot across an average of 10.9 separate security consoles, losing over 20% of their weekly capacity to manually aggregating fragmented data.

Existing mitigation systems work at two levels. Centralised correlation tools — SIEM (collects and correlates events), SOAR (automates repetitive response workflows), and EDR/XDR (correlates endpoint and cloud telemetry at the source) — reduce raw noise but are limited by incomplete data ingestion. Algorithmic Alert Prioritisation (AP) instead ranks alerts so analysts see the most critical first; Jalalvand et al. (2024, ACM Computing Surveys) established a taxonomy of five ranking criteria (Analyst, Alert, Asset, Organisation, External Environment) combined through methods such as Machine Learning risk scoring, Multi-Criteria Decision-Making (MCDM), game-theoretic models, optimisation algorithms, or graph-based provenance analysis that traces causal relationships across system processes. Beyond pure automation, Chhetri et al. (2024, ACM TOIT) proposed the A2C (Automated, Augmented, Collaborative) framework, in which the AI fully automates only high-confidence routine cases, defers uncertain cases to an analyst with structured context (Augmented Deferral), and enters interactive joint investigation with the analyst for genuinely novel threats (Collaborative Exploration).

This three-mode structure is a deliberate departure from a single, fixed automation level: by explicitly recognizing when a case falls inside versus outside the AI's confidence boundary, A2C aims to reserve human attention specifically for the alerts where human judgment adds the most value, rather than distributing analyst effort evenly across all incoming alerts regardless of certainty.

2.4 Problem 4 — Adversarial Evasion Attacks Against ML-Based IDS

Title of Article: DEMGAN: A Machine Learning-Based Intrusion Detection System Evasion Scheme
Authors: Xu et al.
Article Source: Computers, Materials & Continua (CMC), Tech Science Press
Year of Publication: 2025

Adversarial evasion exploits a vulnerability in the ML model itself: by adding tiny, mathematically calculated perturbations to input features, an attacker can manipulate a model's decision at inference time, causing an accurate IDS to misclassify malicious traffic as benign. Unlike an image, a network packet's features are semantically bound (a packet's total length must mathematically equal its header plus payload size), so an attacker cannot perturb one feature without recalculating every related feature, or the packet becomes physically invalid and is dropped before it ever reaches the classifier.

White-box attacks (where the attacker has full access to the model) use gradient-based methods such as FGSM (a fast, single-step perturbation) and BIM (a stronger, iterative version). Black-box attacks instead use Universal Adversarial Perturbations (UAPs) — a single, pre-computed perturbation applied to any traffic flow without per-instance calculation, solving the real-time speed problem. Zhang et al. (2025, University of Warwick) demonstrated a customized UAP against a Deep Reinforcement Learning based IDS using a Pearson Correlation loss function, achieving a 90% false negative rate versus a 40% ceiling for standard UAPs. Xu et al. (2025) went further with DEMGAN, a multi-generator GAN with a dedicated generator per attack family, which achieved a 100% evasion rate against deep models (CNN, RNN, MLP).

The standard defense, adversarial retraining, mixes generated adversarial samples back into the training data; Xu et al. (2025) reported this increased adversarial recognition by an average of 86.78% across model types, reducing attacker evasion success to below 5% for most of the architectures tested (CNN, RNN, CNN-BiLSTM, MLP, DT, and Logistic Regression).

3. Research Gaps / Limitations Identified

Across all four problems, existing systems solve part of the detection challenge but introduce a new operational cost or blind spot elsewhere. For each problem, this section summarizes what the existing system still fails to address, and how the proposed system for this project responds to that specific gap.

3.1 Problem 1 — Zero-Day / Unknown Attack Detection

Existing System — Limitations

Every existing detection method carries a distinct weakness that becomes serious against a genuinely new attack:

- Signature-based detection is blind to unknown threats by design — with no matching signature, it produces no alert regardless of how the malware behaves.
- Sandboxes can be evaded by malware built with dormant or trigger-based logic that stays inactive during the isolated test window and only activates once released into production.
- Supervised classifiers require large volumes of labelled attack data, which is fundamentally unavailable for attacks that have not yet been observed, and are frequently criticized for a lack of explainability.
- Unsupervised anomaly detectors used alone struggle to separate genuine malicious anomalies from benign but unusual operational noise, driving a high rate of false positives.
- Both supervised and unsupervised models are vulnerable to adversarial perturbation: research shows detection accuracy can collapse from over 90% to as low as 64% with small, deliberately crafted input noise.

Proposed System — This Project's Response

The proposed system uses a two-tier hybrid architecture instead of any single method in isolation: an Autoencoder first learns the statistical baseline of normal network traffic, and any traffic it reconstructs poorly is passed to an XGBoost/Random Forest classifier, which determines whether it matches a known attack category or should be treated as a novel threat. This does not require a known signature or a labelled example of every possible attack type to flag suspicious behaviour and is directly validated by Dai et al. (2024), whose equivalent hybrid reached 99.97-99.98% accuracy on entirely unseen attack data.

A SHAP explainability layer is applied on top of the classifier's output, so every flagged threat carries a human-readable justification, directly resolving the black-box criticism raised against tree-ensemble classifiers, and lightweight feature selection keeps the model's computational footprint low enough for near-real-time use.

3.2 Problem 2 — Encrypted Traffic Blind Spot

Existing System — Limitations

The two existing approaches to encrypted traffic each trade one weakness for another:

- TLS decryption proxies introduce significant latency, require enterprise-wide certificate distribution, and completely break Certificate Pinning, causing pinned applications to reject the interception certificate outright.
- Decrypting traffic immediately exposes sensitive data (credentials, financial details, health records); under GDPR, HIPAA, and PCI DSS this creates direct legal liability.
- Handshake fingerprints such as JA3 are observable signals, not immutable identities — an attacker who controls the client software can deliberately randomize the handshake to generate a different fingerprint on every connection.
- Even privacy-preserving protocols are not immune to implementation bugs: CVE-2026-42505 (July 2026) revealed that Go's crypto/tls library leaked pre-shared key identities into the unencrypted outer ClientHello of ECH connections, allowing a passive observer to de-anonymize handshakes the protocol was designed to protect.

Proposed System — This Project's Response

The proposed system adopts a no-decrypt, metadata-driven approach, training on packet-size sequences (SPLT), connection duration, protocol/flag combinations, and TLS handshake attributes rather than payload content — avoiding both the latency and legal exposure of decryption while still extracting a usable signal. It follows the CNN-BiLSTM architecture validated by Muttaqien et al. (2025), reaching 98.7% accuracy with a 1.4% false-positive rate at 12.9 ms per session.

Because JA3/JA4 fingerprints can be deliberately randomized, the fingerprint is treated as one signal among several (combined with SPLT and timing) rather than the sole basis for a decision, so fingerprint evasion alone cannot flip the classification. In line with NIST SP 1800-37's 'middle path', full decryption is reserved only for a narrow, pre-defined set of high-risk internal assets, avoiding blanket interception entirely.

3.3 Problem 3 — Alert Fatigue from High False-Positive Rates

Existing System — Limitations

Current prioritisation and automation systems each hit a different structural limit:

- SIEM ingestion is structurally incomplete — only around 59% of security tools automatically push data into the SIEM via API, forcing most SOCs to manually ingest data on a recurring basis.
- MCDM frameworks (e.g., AHP, TOPSIS) struggle with non-ordinal security data: fields such as IP addresses and filenames cannot be meaningfully sorted, limiting their effectiveness without heavy custom preprocessing.
- The 'false-positive paradox': even a highly accurate model with a residual false-positive rate as low as 1.4-5% still produces thousands of daily false alerts on a high-throughput enterprise network, so higher accuracy alone does not solve analyst overload.
- Explainability tools such as SHAP or LIME are meant to build analyst trust, but if their output is itself unclear, analysts either ignore the prioritisation entirely or manually double-check every alert regardless, defeating its purpose.

Proposed System — This Project's Response

The proposed system combines the classifier's confidence score and the anomaly-detection layer's reconstruction error (from Problem 1) with a small set of ordinal, easily-comparable criteria drawn from the Jalalvand et al. (2024) taxonomy — alert severity and asset criticality — into a single composite priority score, deliberately avoiding the MCDM non-ordinal pitfall by combining only already-numeric or tiered features.

This priority score drives a tiered triage flow loosely inspired by the A2C framework but scoped to what is realistically implementable: very high-confidence, low-severity predictions are auto-logged; high-confidence, high-severity predictions are surfaced immediately as critical alerts; and medium-confidence or borderline predictions go to an analyst review queue, each with a SHAP-based explanation of which features drove the score — concentrating analyst attention on the smaller set of genuinely uncertain cases rather than every alert equally.

3.4 Problem 4 — Adversarial Evasion Attacks

Existing System — Limitations

Both the attack and defense sides of this problem reveal structural weaknesses:

- Enforcing realistic domain constraints causes over a 50% loss in evasion effectiveness for BIM compared to unconstrained attacks, meaning much of the published literature that ignores these constraints overstate real-world evasion capability.
- Generative evasion models show a 'simplicity paradox' — DEMGAN reaches a 100% evasion rate against complex, non-linear models (CNN, RNN, MLP) but noticeably lower evasion against simpler classifiers such as Decision Trees, meaning a more sophisticated model is not automatically more robust.
- Adversarial retraining, the primary defense, is fundamentally reactive: it only defends against evasion techniques it has already seen. When Zhang et al.'s PCC-optimized UAP (90% false-negative rate) is compared against the older baseline it defended against (40% ceiling), a retrained model's protection collapses again, restarting an expensive retraining cycle.

Proposed System — This Project's Response

The proposed system adopts adversarial retraining as its core defense: a set of adversarial samples is generated against the project's own XGBoost/Autoencoder classifier using constrained perturbations that respect real feature-dependency rules, and mixed into training data, following the same before/after methodology reported by Xu et al. (2025), which increased recognition by 86.78% on average.

The system also deliberately leans on the 'simplicity paradox': because generative evasion attacks are most effective against deep, non-linear models, the project's XGBoost/Random Forest classifier (already chosen for Problem 1) is intentionally kept as the primary decision layer rather than replaced with a deeper architecture purely to chase marginal accuracy gains, since deep models are empirically the more attractive target for an adversary.

Honest scope note: this is a mitigation, not a permanent fix — no current published system achieves permanent evasion-proof detection, and this project does not claim to either.

4. Summary / Conclusion of Review

The literature reviewed shows that Machine Learning has meaningfully improved network threat detection over purely signature-based approaches, but four specific gaps remain open even in current (2024-2026) research: detecting attacks with no training precedent, maintaining visibility once traffic is encrypted, keeping false-positive volume low enough for analysts to act on, and resisting deliberate adversarial manipulation of the model itself. Each gap has a validated, published mitigation — hybrid Autoencoder-ensemble models for zero-day detection, metadata-driven CNN-BiLSTM classification for encrypted traffic, confidence-and-severity-based alert ranking for fatigue, and constrained adversarial retraining for evasion resistance — but no single existing system combines all four.

This review directly informs the design of the proposed ML-Based Cyber Threat Prediction System: an XGBoost/Random Forest classifier paired with an Autoencoder/Isolation Forest anomaly layer (Problem 1) forms the detection core; this core is deliberately kept as a tree-ensemble rather than a deep neural network, since the literature shows tree-ensembles are empirically harder to evade (Problem 4); the same classifier is applied to flow/handshake metadata rather than payload content so it functions on encrypted traffic without decryption (Problem 2); and its confidence and anomaly scores feed a risk-ranked, SHAP-explained alert dashboard so its output remains usable by a human analyst rather than adding to alert fatigue (Problem 3). In this way, the proposed system is not a single novel algorithm, but a deliberate integration of four separately validated research directions into one coherent design.

References

Dai, Z., Por, L. Y., Chen, Y.-L., Yang, J., Ku, C. S., Alizadehsani, R., & Pławiak, P. (2024). An intrusion detection model to detect zero-day attacks in unseen data using machine learning. PLOS ONE. https://www.ncbi.nlm.nih.gov/pmc/articles/PMC11389943/

A Survey of AI-Based Zero-Day Attack Detection Methods (2025). https://www.researchgate.net/publication/394317694_A_Survey_of_AI-Based_Zero-Day_Attack_Detection_Methods

Detecting new obfuscated malware variants: A lightweight and interpretable machine learning approach (2024). arXiv:2407.07918. https://arxiv.org/pdf/2407.07918

Muttaqien, H., Niswar, M., Syarif, S., & Zainuddin, Z. (2025). Enhancing Network Intrusion Detection for TLS Traffic Using Deep Learning. Engineering, Technology & Applied Science Research (ETASR), 15(6), 28530-28536. https://etasr.com/index.php/ETASR/article/view/13267

NIST SP 1800-37 (2025). Detecting and Protecting Against Malicious Activity on Encrypted Network Traffic. National Institute of Standards and Technology.

Vectra AI (2026). Encrypted traffic analysis: what survives TLS, QUIC, and ECH. https://www.vectra.ai/topics/encrypted-traffic-analysis

CVE-2026-42505 (2026). crypto/tls: Encrypted Client Hello Privacy Leak via PSK in Outer ClientHello. Go Vulnerability Database, GO-2026-5856. https://pkg.go.dev/vuln/GO-2026-5856

Jalalvand, F., Chhetri, M. B., Nepal, S., & Paris, C. (2024). Alert Prioritisation in Security Operations Centres: A Systematic Survey on Criteria and Methods. ACM Computing Surveys, 57(2), Article 42. https://dl.acm.org/doi/full/10.1145/3695462

Chhetri, M. B., Tariq, S., Singh, R., Jalalvand, F., Paris, C., & Nepal, S. (2024). Towards Human-AI Teaming to Mitigate Alert Fatigue in Security Operations Centres. ACM Transactions on Internet Technology, 24(3), Article 12. https://dl.acm.org/doi/10.1145/3670009

Microsoft & Omdia (2026). State of the SOC: Unify Now or Pay Later. Microsoft Security Research. https://www.microsoft.com/en-us/security/blog/2026/02/17/unify-now-or-pay-later-new-research-exposes-the-operational-cost-of-a-fragmented-soc/

Zhang, H., Zhang, L., Epiphaniou, G., & Maple, C. (2025). A Novel and Practical Universal Adversarial Perturbations against Deep Reinforcement Learning based Intrusion Detection Systems. arXiv:2511.18223. https://arxiv.org/abs/2511.18223

Xu et al. (2025). DEMGAN: A Machine Learning-Based Intrusion Detection System Evasion Scheme. Computers, Materials & Continua, Tech Science Press. https://www.sciopen.com/article/10.32604/cmc.2025.064833